

Phishing Incident Response Playbook

Framework: NIST SP 800-61 Rev. 2

Role / Author: Junior SOC Analyst

Version: 1.0

1. Preparation

- **Emergency Contacts:**
 - SOC Team: soc-team@company.com
 - IT Helpdesk: Ext 101 / helpdesk@company.com
- **Analysis Tools:** VirusTotal, MXToolbox (Header Analyzer), URLScan.io
- **Prerequisites:** Regular automated backups enabled, multi-factor authentication (MFA) enforced.

2. Detection & Analysis

- **Trigger:** User reports a suspicious email or Mail Gateway flags an alert.
- **Analysis Steps:**
 - Check sender email address (look for typosquatting, e.g., [paypa1.com](https://www.paypal.com)).
 - Inspect email body for urgent language or suspicious requests.
 - Check attachments via sandbox/VirusTotal (do not run directly).
 - Hover over hyperlinks to confirm actual destination URLs.

3. Containment, Eradication & Recovery

- **Containment:**
 - Ask if the user clicked links or submitted credentials.
 - If yes, immediately disconnect the device from network (unplug LAN / disconnect Wi-Fi).
 - Reset user credentials and revoke all active sessions/tokens.
- **Eradication:**
 - Purge/delete the malicious email from all company mailboxes.
 - Block the malicious sender domain and URL on the perimeter firewall/gateway.
- **Recovery:**
 - Run full antivirus/EDR scan on affected endpoints.
 - Re-enable network access once verified clean.

4. Post-Incident Activity & Tabletop Exercise

- **Tabletop Findings:** During our simulation, we noted users might submit 2FA codes on phishing pages. Added step to immediately revoke MFA session cookies.
- **Lessons Learned:** Schedule quarterly phishing awareness training for departments handling sensitive data.